People: who gets which report?

Observing people (1/2)

People tend to follow the three Westrum culture patterns:

- pathological
- bureaucratic
- generative.

Sonatype produces annual report measuring happiness:

- Happy Devs do more security.
- Reduce points of friction.

Happiness as retrospective topic:

- sources of friction
- ways to improve
- interaction with teams.

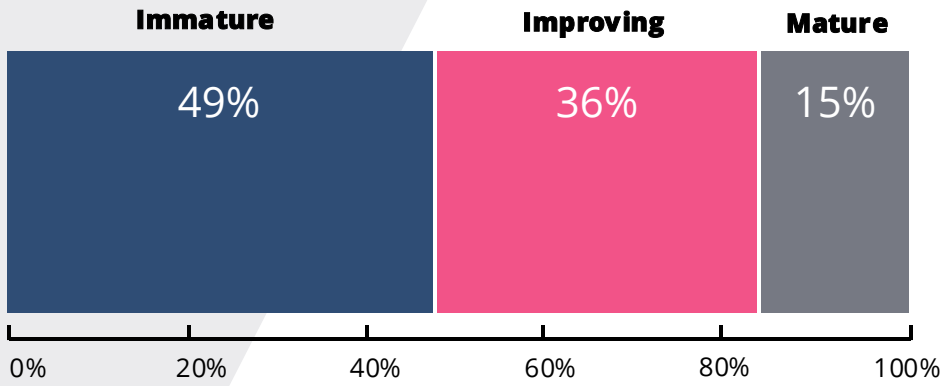
Westrum culture model

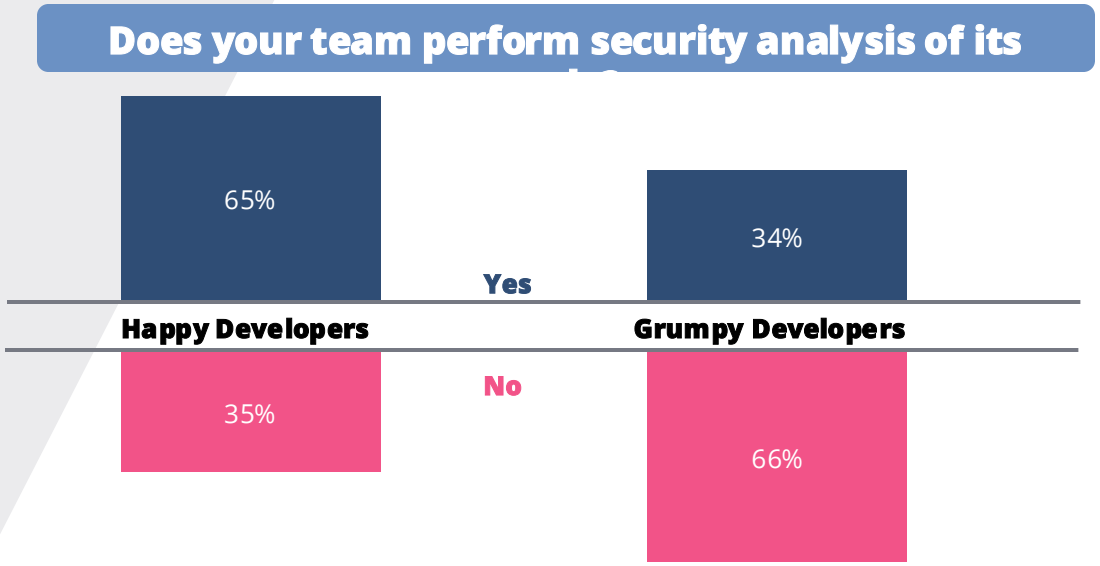
Pathological	Bureaucratic	Generative
Power oriented	**Rule oriented**	**Performance oriented**
Low cooperation	Modest cooperation	High cooperation
Messengers shot	Messengers neglected	Messengers trained
Responsibilities shirked	Narrow responsibilities	Risks are shared
Bridging discouraged	Bridging tolerated	Bridging encouraged
Failure leads to scapegoating	Failure leads to justice	Failure leads to inquiry
Novelty crushed	Novelty creates problems	Novelty implemented

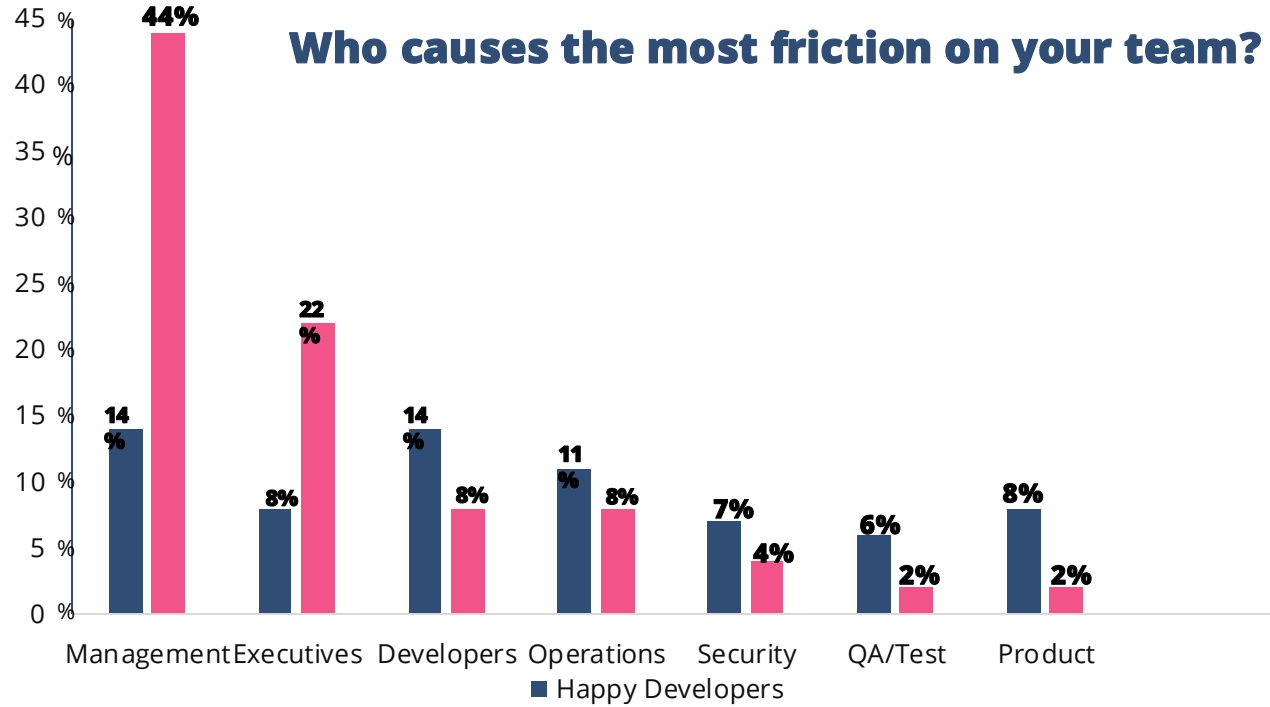
Source: https://www.excella.com/insights/3-types-of-cultur

Copyright© 2025 PeopleCert International Ltd.

Observing people (2/2)







Copyright© 2025 PeopleCert International Ltd.

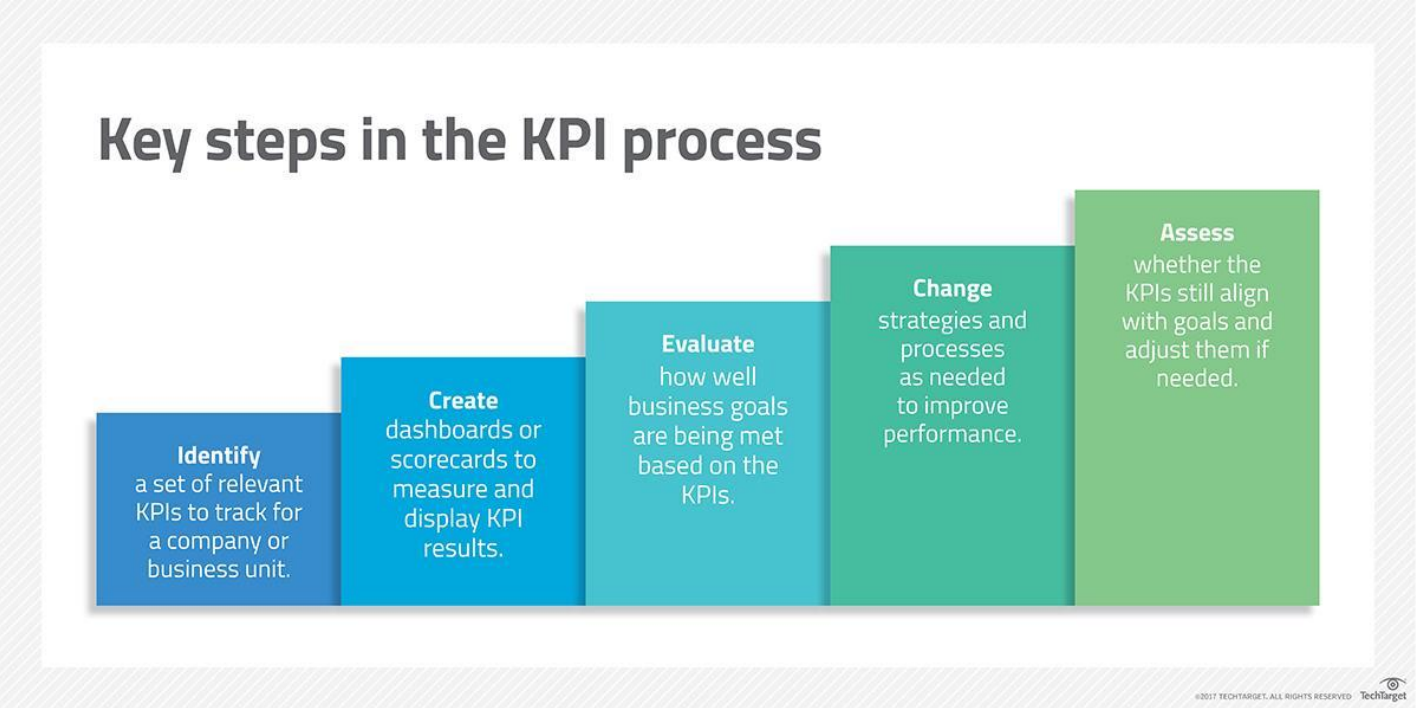
Targeting metrics

Conway's Law guides behaviours:

- Structure of software mirrors the structure of the organization.
- Metrics should indicate organization security performance.

Other use cases:

- security feature prioritization
- unplanned security work
- SLA for security compliance
- application security performance.



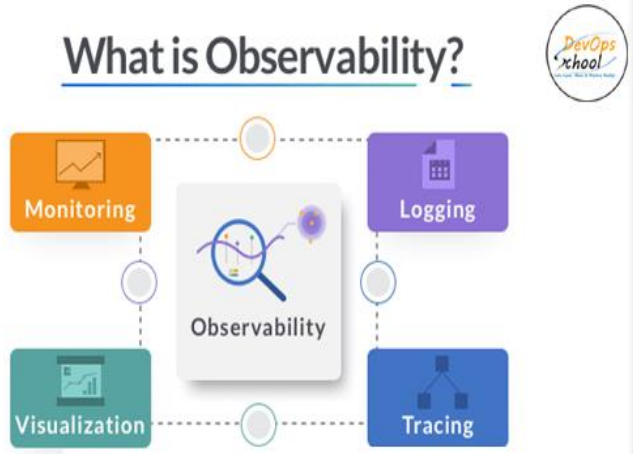
Source: https://www.abtasty.com/blog/key-performance-indicator/

Copyright© 2025 PeopleCert International Ltd.

DevSecOps observability dashboards

- Observable dashboards consume storage; raw logs and traces are more efficient.
- Agree on formats/ storage times early.
- Check your tools for best practices.

Data storage tips



Source: https://professnow.com/blog/what-is-monitoring-and-observability-what-are-the-differences/

- Do I need an observability expert?
  - Monitor.
  - Collaborate.
  - Automate.
- Who sets the team mindset for observability?
- What are the timelines to identify and fix a problem?
- Who controls the data?

Copyright© 2025 PeopleCert International Ltd.

How much observability (for security in DevSecOps) is enough?

Too much

- observability for observability's sake
- too many metrics
- false positive and false negative security results
- complex dashboards.

Not enough

- unable to measure lead time for secure releases
- unable to validate whether releases satisfy security goals
- unable to measure cycle time for each security stage in the value stream
- unable to determine cost of security.

Discussion

- How to make security observable?
- Frequency of secure releases?
- Lead time for secure release?
- Cost for secure release?
- Rate of security innovation?



Copyright© 2025 PeopleCert International Ltd.

SRE role in DevSecOps observability

Set measurable security goals.

Establish security indicators.

SREs play a key role for security

SREs help determine goals and actions for security:

- service level agreement; organization.
- service level objective; team.
- service level indicators; action.

Challenges:

- SRE skills for security
- prioritizing security fixes
- SREs coverage across multiple teams.

Collaborate and coordinate.

Who owns SRE?

Copyright© 2025 PeopleCert International Ltd.